

サイバー攻撃への対策

- c社は首都圏に複数の販売店をもつ、中堅の中古車販売会社
- c社はS県に複数の中古車販売店舗を展開するP社と業務提携しており、P社の中古車情報もB社の販売管理システムに登録した上で販売している

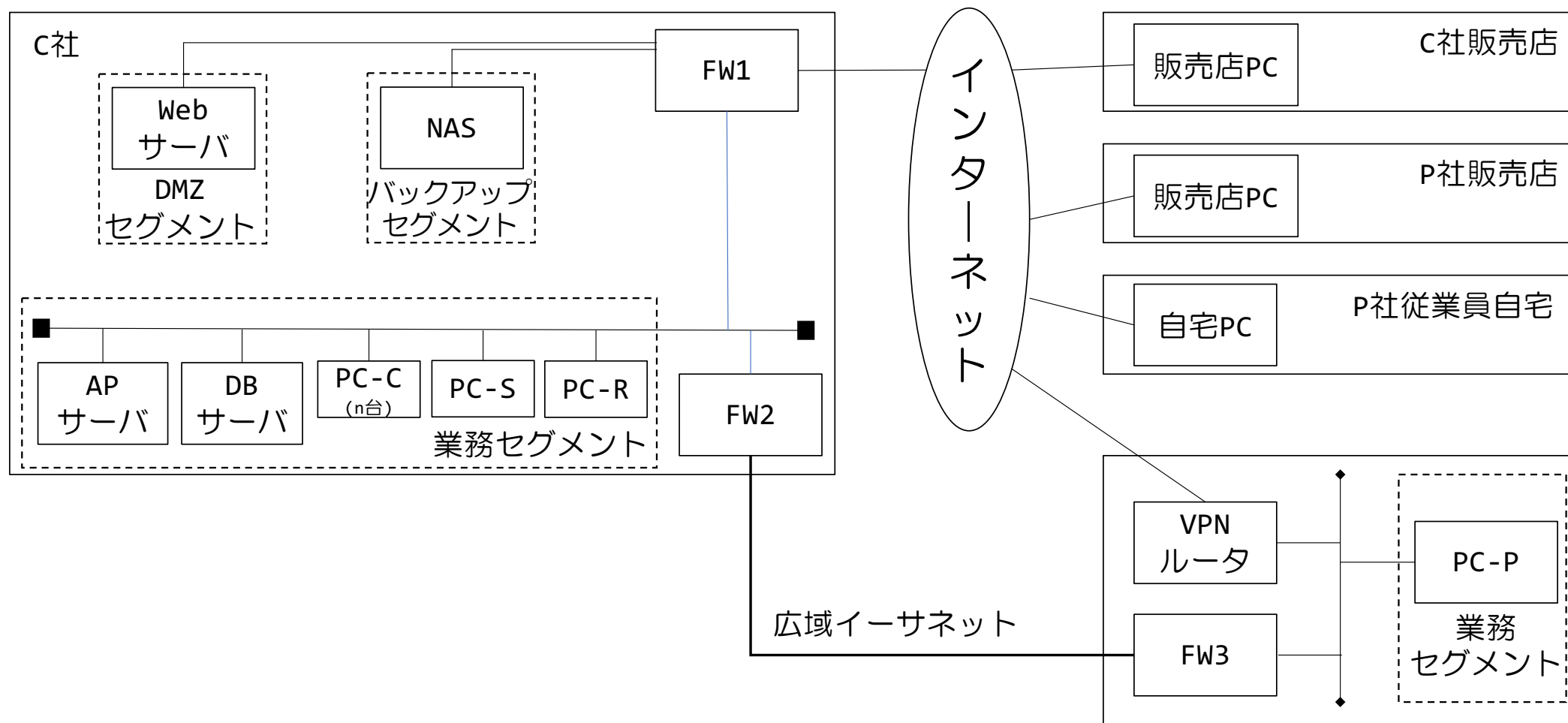
C社販売管理システム(1)

- C社販売管理システムは以下のサーバで構成
 - Webサーバ
 - アプリケーションサーバ(以下, APサーバ)
 - データベースサーバ(以下, DBサーバ)
- C社およびP社の販売店
 - Webサーバを経由して中古車情報や販売実績を登録
- C社の販売店の情報
 - C社内のPC(以下, PC-C)から, APサーバの販売店情報登録ツール(以下, 販売店ツール)を利用して登録

C社販売管理システム(2)

- 販売管理システムのメンテナンス
 - 販売管理システムを構成するWebサーバ、APサーバ、DBサーバ(以下、C社各サーバ)は、C社の社内システム担当者が、社内システム用PC(以下、PC-S)から管理者権限のあるID(以下、特権ID)でC社各サーバにログインしてメンテナンスを実施
- P社の販売店情報
 - P社従業員が、社内に設置したP社販売店情報登録用PC(以下、PC-P)から、C社内に設置したP社販売店情報登録用PC(以下、PC-R)にリモートデスクトップでログインし、販売店ツールを利用して登録
- P社のリモートワーク環境
 - P社従業員の自宅PC(以下、自宅PC)からSSL-VPNを利用して、PC-Pにリモートデスクトップでログインできる環境を構築

C社およびP社のネットワーク構成



ファイアウォール(FW)のアクセス制御リスト

機器	送信元	宛先	プロトコル/ポート番号
FW1	ANY	DMZセグメント	HTTPS(443/tcp)
FW1	Webサーバ	APサーバ	HTTP(80/tcp)
FW1	Webサーバ	バックアップ セグメント	SSH(22/tcp)
FW1	APサーバ DBサーバ	バックアップ セグメント	SSH(22/tcp)
FW2	P社の業務 セグメント	C社の業務 セグメント	RDP(3389/tcp)
FW3	P社の業務 セグメント	C社の業務 セグメント	RDP(3389/tcp)

各FWは、応答パケットを自動的に通過させるステートフルインスペクション機能を有する

c社におけるセキュリティ対策

- c社各サーバでのセキュリティ対策
 - マルウェア対策ソフトウェアがインストール
 - 毎日午前0時30分～午前1時30分の間にデータをバックアップ
 - 月曜日にデータのフルバックアップを実施
 - 火曜日から日曜日まではデータの差分バックアップを実施
 - NASには月曜日を起点として最大7日分のバックアップを1世代分保存
 - 次の世代のデータは前の世代のデータに上書き保存
 - システムバックアップもNASに保存

ログ

- C社およびP社の各PC，各サーバおよびネットワーク機器のログは，各機器内部に保存しており，ログのサイズが最大値に達すると，古い記憶から上書きするように設定

ログイン失敗時の動作

- C社の各PCおよび各サーバでは、ログインのロックアウトのしきい値を5回に設定
 - ログイン失敗を5回繰り返すとロックアウト

セキュリティインシデントの発生

- ある月曜日の午前9時頃，c社のシステム部門に，c社販売店から販売管理システムが利用できないと報告
- システム部門のR主任が販売管理システムを調査したところ，c社各サーバのデータが暗号化されていることが判明した
- R主任は，外部のセキュリティ会社U社に連絡してインシデントの調査を依頼
- U社のX氏から，電磁的記録の証拠保全，調査および分析をおコアに
ので，c社内のインターネットと広域イーサネットに接続している
ネットワークを遮断した後，すべてのPCの使用を停止してください
と要請があり，R主任は要請に従った

セキュリティインシデントの調査(1)

- X氏から、”PC、サーバ及びネットワーク機器のログを分析した結果、侵入者は次の順序で攻撃していたことが判明した”と報告があった
 - ① インシデントの報告日の午前3時15分に、PC-PからPC-Rにログイン
 - ② PC-Rと同じパスワードのログインIDがPC-Sに存在しており、PC-Rのログインに利用したパスワードで、PC-Sにリバースブルートフォース攻撃を行い、PC-Sにログイン
 - ③ 社内システム担当がサーバにログインする際に利用したIDとパスワードをPC-Sのメモリ上に保存するというPC-Sのアプリケーションソフトウェアの脆弱性を利用して、C社各サーバにログイン
 - ④ C社各サーバのマルウェア対策ソフトウェアのプロセスを強制終了して、ランサムウェアを実行

セキュリティインシデントの調査(2)

- X氏は、”侵入経路であるP社の機器もC社と同様に電磁的記録の証拠保全、調査及び分析の必要があるので、P社へ連絡するように”とR主任に要請
- X氏が、PC-PおよびP社のネットワーク機器を調査した結果、次の状況が発覚
 - VPNルータには認証に関する脆弱性が存在
 - 攻撃に利用されたPC-PのIDとパスワードは、PC-Rと同じだった
 - PC-PのIDは”admin”で特権IDであり、パスワードは”password123456”
 - PC-PへはID”administrator”に対して異なるパスワードで約1万回ログイン試行に失敗した後、ID”admin”に対して異なるパスワードで150回ログイン試行に失敗して、151回目でログインに成功

暫定対応およびシステム復旧対応

- 侵入経路と原因が判明したので，R主任およびP社は次の暫定対応を実施し，C社各サーバのシステムおよびデータをバックアップデータから復旧の上，販売管理システムの利用を開始
- 暫定対応
 - VPNルータとPC-Sのアプリケーションソフトウェアに，脆弱性対応した修正プログラムを適用
 - PCおよびサーバのIDとパスワードを推測が困難で複雑なものへ変更
 - 侵入経路となったPC-Pの設定を変更
 - どのような設定変更が有効か？
 - アクセスルールの変更含む

U社からC社への報告

- U社はC社へ，調査結果をC社の課題として報告
- 抜粋したC社の課題を示す

項番	課題(抜粋)
1	C社に接続するP社のPCおよびネットワーク機器について，機器管理や脆弱性管理ができていない
2	侵入者が特権IDでログインし，今回のようにC社各サーバで操作した場合，マルウェアを検知できなくなる
3	インシデントの報告日の前日にランサムウェアに感染して暗号化されていた場合，バックアップデータからの復旧に問題が生じた可能性がある また，NASに侵入されてバックアップデータが暗号化されるリスクもある
4	一定期間に大量の攻撃を受けた場合，過去に発生した事象が調査できなくなる可能性がある

課題に対する対策案の検討(1)

- R主任は、課題に対する対策案を検討した

項番	課題(抜粋)
1	C社に接続するP社のPCおよびネットワーク機器について、機器管理や脆弱性管理ができていない
項番1への対策	
• C社に接続するP社のPCおよびネットワーク機器の情報をP社から提供してもらい、機器の一覧を作成 • P社に運用ルールの作成を依頼し、作成した運用ルールが適切であることを確認	

課題に対する対策案の検討(2)

- R主任は、課題に対する対策案を検討した

項番	課題(抜粋)
2	侵入者が特権IDでログインし、今回のようにc社各サーバで操作した場合、マルウェアを検知できなくなる

項番2への対策

- R主任を特権ID管理者とし、R主任が許可した場合だけ、特権IDを利用可能にする運用ルールを作成
- R主任が許可した場合には、特権IDにワンタイムパスワードを設定し、利用者に払い出す仕組みを導入

課題に対する対策案の検討(3)

- R主任は、課題に対する対策案を検討した

項番	課題(抜粋)
3	インシデントの報告日の前日にランサムウェアに感染して暗号化されていた場合、バックアップデータからの復旧に問題が生じた可能性がある また、NASに侵入されてバックアップデータが暗号化されるリスクもある

項番3への対策

- バックアップデータが暗号化されないように、NASに加えて別のストレージにバックアップデータを保存
- バックアップデータは3世代分保存

課題に対する対策案の検討(4)

- R主任は、課題に対する対策案を検討した

項番	課題(抜粋)
4	一定期間に大量の攻撃を受けた場合、過去に発生した事象が調査できなくなる可能性がある
項番4への対策	
• ログ管理サーバを設置し、PC、サーバおよびネットワーク機器のログを保存	

対策案の承認

- R主任は、C社内の再発防止会議で対策案を報告し、承認

原因調査

- 今回のインシデントの根本的な原因はどこにあるのか？
- 問題点となる箇所をできる限り列挙
- 列挙した問題点を踏まえ、どのような運用ルールを作成すれば良いか
- さらに、抜粋した課題への対策で十分かどうか抜けはないか検討しなさい

暫定対応およびシステム復旧対応

- 侵入経路と原因が判明したので，R主任およびP社は次の暫定対応を実施し，C社各サーバのシステムおよびデータをバックアップデータから復旧の上，販売管理システムの利用を開始
- 暫定対応
 - VPNルータとPC-Sのアプリケーションソフトウェアに，脆弱性対応した修正プログラムを適用
 - PCおよびサーバのIDとパスワードを推測が困難で複雑なものへ変更
 - 侵入経路となったPC-Pの設定を変更
 - どのような設定変更が有効か？
 - アクセスルールの変更含む

対策案

- 課題
 - バックアップデータの復旧に問題が生じていた可能性とはどのようなことか説明しなさい

項番	課題(抜粋)
3	<u>インシデントの報告日の前日にランサムウェアに感染して暗号化されていた場合、バックアップデータからの復旧に問題が生じた可能性がある</u> また、NASに侵入されてバックアップデータが暗号化されるリスクもある

項番3への対策

- バックアップデータが暗号化されないように、NASに加えて別のストレージにバックアップデータを保存
- バックアップデータは3世代分保存

対策案

- 課題への対策
 - どのような性質をもつストレージシステムにバックアップデータを保存すればよいのか？

項番	課題(抜粋)
3	<u>インシデントの報告日の前日にランサムウェアに感染して暗号化されていた場合、バックアップデータからの復旧に問題が生じた可能性がある</u> また、NASに侵入されてバックアップデータが暗号化されるリスクもある

項番3への対策

- バックアップデータが暗号化されないように、NASに加えて別のストレージにバックアップデータを保存
- バックアップデータは3世代分保存